

初級資訊安全工程師能力鑑定樣題

科目 2：資訊安全技術概論

第 1 頁，共 9 頁

單選題 50 題（佔 100%）

C	1. IP 之間的傳輸，屬 OSI 模型哪一層次？ (A) 應用層（Application Layer） (B) 表達層（Presentation Layer） (C) 網路層（Network Layer） (D) 傳輸層（Transport Layer）
C	2. 下列哪種攻擊可以用來繞過實體（Physical）和邏輯（Logical）主機安全機制？ (A) 暴力攻擊（Brute-Force Attack） (B) 阻斷服務攻擊（Denial-of-Service Attack） (C) 社交工程（Social Engineering） (D) 通訊埠掃描（Port Scan）
A	3. SMURF Attack 是利用何種協定進行攻擊？ (A) ICMP (B) UDP (C) RIP (D) ARP
A	4. 公司對外的網站放置於下列何處？ (A) DMZ（Demilitarized Zone） (B) Internet (C) Intranet (D) Extranet
C	5. 某管理員監控網路上的 IP 封包時，發現封包標頭包含了一個協定欄位（Protocol Number），而此欄位的值為 1，請問此封包是屬於何種協定的封包？ (A) TCP (B) UDP (C) ICMP (D) IGMP
C	6. 請問下列何種網路攻擊行為會使目標主機系統超出其工作負荷量，甚至導致系統癱瘓？ (A) 社交攻擊（Social Engineering） (B) 流量分析（Traffic Analysis） (C) 阻斷式服務攻擊（Denial-of-Service Attack） (D) 竊聽（Sniffing）
C	7. 下列設備中，何者是可避免內外直接連線並隱藏內部 IP 位址？

初級資訊安全工程師能力鑑定樣題

科目 2：資訊安全技術概論

第 2 頁，共 9 頁

	(A) 封包過濾防火牆 (Packet-Filtering Firewall) (B) 狀態檢視防火牆 (Stateful Inspection Firewall) (C) 代理伺服器 (Proxy Server) (D) 網站應用程式防火牆 (Web Application Firewall)
B	8. 在寄送電子郵件時，可以運用安全電子郵件簽章/密碼技術，以確保資訊的哪些特性？ (1) 機密性 (2) 完整性 (3) 可用性 (4) 鑑別性 (A) (1), (2), (3) (B) (1), (2), (4) (C) (1), (3), (4) (D) (2), (3), (4)
D	9. 關於「SSL 協定」，下列敘述何者不正確？ (A) 提供伺服器(Server)驗證 (B) 提供客戶端(Client)安全傳輸 (C) 提供伺服器(Server)與客戶(Client)之間的通訊加密 (D) 可絕對確保買賣交易的安全
A	10. 關於 TCP 協定的特性，下列敘述何者正確？ (A) 確保資料傳送之正確性 (B) 資料開始傳送時不需進行交握(Hand shaking) (C) 傳送發生錯誤時不會要求重新傳送 (D) 傳送時所進行之檢查與偵錯機制較 UDP 簡單
C	11. 請問下列何者非為應用層服務？ (A) HTTP (B) SMTP (C) IPX (D) FTP
B	12. 下列哪一項網路技術可以降低廣播領域 (Broadcast Domain) 範圍？ (A) Network Address Translate (NAT) (B) VLAN (C) Dynamic Trunking Protocol (D) Inter-Switch Link (ISL)
C	13. 下列敘述何者不正確？ (A) 木馬後門程式常偽裝成提供便利或實用的免費軟體，吸引使用者

初級資訊安全工程師能力鑑定樣題

科目 2：資訊安全技術概論

第 3 頁，共 9 頁

	下載使用 (B) 電腦病毒具有散播、隱藏、感染、潛伏及破壞等特性 (C) 阻絕服務攻擊 (DoS) 通常指攻擊者與通訊的兩端分別建立獨立的聯繫，並交換所收到的資料 (D) 蠕蟲 (Worm) 會不斷複製，並利用網路感染其他主機
C	14. 雙因認證 (Two-Way Factor) 可以防止下列何者攻擊？ (A) 阻斷式服務攻擊 (B) SQL 資料隱碼攻擊 (C) 密碼側錄攻擊 (D) 中間人攻擊
C	15. 請問此 <code>cat ~/.bash_history</code> 指令的目的為？ (A) 列出使用者目錄 (B) 列出系統目錄 (C) 列出使用者曾經下過的指令 (D) 列出系統安裝歷史
C	16. 下列何者實務做法對於強化作業系統本身保護，降低被攻擊風險並沒有太大的效益？ (A) 定期自動更新 (B) 啟用預設拒絕政策的系統防火牆 (C) 啟用 IPSec 服務 (D) 安裝並更新防毒軟體
D	17. 下列何者不屬於作業系統安全預防(Preventive)機制？ (A) 實施密碼原則 (B) 安裝防毒軟體 (C) 定期套用安全性更新 (D) 定期檢視安全記錄檔 (Log)
A	18. 黑帽駭客 (Black Hats) 入侵前，收集資訊常用的指令 <code>nslookup</code>，下列何者不是其目的？ (A) 可以用來掃描已開啟的 TCP/UDP Port (B) 可以用來診斷 DNS 的架構 (C) 可以用來查詢網路網域名稱伺服器 (D) 如果以 DNS 的名稱，尋找主機 IP 位址
D	19. 請問下列何者「並非」作業系統中毒的可能徵狀？ (A) 檔案無故遭加密 (B) 上網速度變慢或無法連線 (C) 無故出現對話框，且無法關閉

初級資訊安全工程師能力鑑定樣題

科目 2：資訊安全技術概論

第 4 頁，共 9 頁

	(D) 資料讀取速度變快
C	20. 請問下列何者不是 XSS (Cross-Site Scripting) 攻擊語法？ (A) <script>alert('xss');</script> (B) +alert('xss')+ (C) ' or 1=1-- (D)
B	21. SQL 資料隱碼攻擊 (SQL Injection) 的攻擊技術主要會發生的原因，是利用下列何者？ (A) 利用系統漏洞對系統造成危害 (B) 程式開發者的疏忽，未對使用者的輸入進行過濾與檢查 (C) 資料庫存取權限設定錯誤所造成 (D) 遭受到駭客運用社交工程及惡意程式攻擊
C	22. 針對資料庫要進行事前告警、及時發現，以及事後分析追查可能的異常存取資安事件，該導入哪種資料庫安全防護措施？ (A) 資料庫加密 (B) 資料庫叢集 (C) 資料庫稽核 (D) 資料庫掃描
C	23. 安全的系統發展生命週期 (Secure Software Development Life Cycle, SSDLC) 意指發展一套安全系統的順序，用以開發完善安全的資訊系統。以下哪個不是安全的系統發展生命週期階段？ (A) 設計 (B) 需求 (C) 估價 (D) 開發
A	24. Android 系統的核心層級應用程式沙箱(Sandbox)是以何種方式來提供安全性？ (A) 每個應用程序指定唯一的使用者識別碼 (UID)，並執行於獨立的處理程序中 (B) 於非特權群組識別碼 (GID) 下執行所有應用程式 (C) 限制核心處理程序進行非法讀取 (D) 防止任何未經授權的核心處理程序執行
C	25. 程式碼簽署 (Code Signing) 無法提供以下哪一項功能？ (A) 確認軟體開發者的身份 (B) 防止程式碼被篡改 (C) 用戶端認證 (D) 程式碼執行時期的合法性識別

初級資訊安全工程師能力鑑定樣題

科目 2：資訊安全技術概論

第 5 頁，共 9 頁

B	26. 下列何者為目前撰寫安全程式碼的知名的業界參考指引？ (A) NIST SP 800 系列 (B) OWASP 指南 (C) FIPS 系列 (D) ISO22301 相關標準
B	27. 關於逆向工程，下列敘述何者正確？ (A) 從組合語言恢復高階語言的結構與語法過程 (B) 從機器語言恢復高階語言的結構與語法過程 (C) 從高階語言恢復組合語言的結構與語法過程 (D) 從高階語言恢復機器語言的結構與語法過程
A	28. 關於原始碼漏洞修補，下列敘述何者不正確？ (A) 所有類型的原始碼漏洞，均可找到對應的弱點掃描方法 (B) 未經驗證的使用者參數，均應加以驗證 (C) SQL Injection 的源頭可能來自於 Web 頁面，亦可能來自資料庫本身資料 (D) XSS 的源頭可能來自於瀏覽器的 Document Object Model
D	29. 關於弱點掃描（Vulnerability Assessment）的描述，下列敘述何者不正確？ (A) 弱點掃描屬於一種網路探測技術 (B) 弱點掃描主要是偵測並掃描位於主機上的各個端口或節點的弱點資訊後，與自身的弱點資料庫進行比對 (C) 若防火牆和入侵偵測系統是屬於被動的防禦方法，則弱點掃描就屬於一種主動的防禦方法 (D) 弱點掃描與原碼檢測（Source Code Analysis）應擇一使用，以避免檢測數據相互干擾
D	30. 下列對行動碼（Mobile code），下列敘述何者不正確？ (A) 通常不具傷害性 (B) 可在不同作業系統之間執行 (C) 可在不同瀏覽器上順利執行 (D) 無法從遠端系統傳到本地端執行
B	31. 關於病毒（Virus）與蠕蟲（Worm）之比較，下列何者最正確？ (A) 病毒通常為惡意程式，蠕蟲則通常不是 (B) 病毒通常透過使用者操作傳播，蠕蟲則會自行擴散 (C) 病毒檔案通常比蠕蟲大 (D) 病毒可自行存在，但蠕蟲無法自行存在

初級資訊安全工程師能力鑑定樣題

科目 2：資訊安全技術概論

第 6 頁，共 9 頁

D	32. 資訊安全管理人員經常接收到資安狀況的回報，需要作出判斷進行相關處置。請問下列哪一現象比較不像遭受到惡意程式的攻擊狀況？ (A) 使用者電腦自動發送大量電子郵件 (B) 使用者電腦系統突然變慢，硬碟大量執行運作 (C) 使用者防毒軟體突然被關閉，失去即時防禦 (D) 使用者電腦收到電子垃圾廣告郵件
B	33. 關於個人資料電子檔案管理，下列敘述何者不正確？ (A) 非業務所需，個人電腦、公用資料夾、公用 PC 不得存放含有個人資料之電子檔案；且存放公用資料夾及公用 PC 之個人資料檔案應依保存期限刪除 (B) 臨時性之個人資料檔案存放於個人電腦、公用資料夾、公用 PC 之暫存資料夾中時，其存放天數不可限制 (C) 個人資料檔案備份應考量備份資料加密之必要 (D) 儲存備份資料之媒體亦應以適當方式保管，且依組織相關規定定期進行備份資料之還原測試，以確保備份之有效性
A	34. 關於資訊回復點（Recovery Point Objective, RPO），下列敘述何者不正確？ (A) RPO 意指當災害發生後，資訊系統恢復基本或必要服務的所需時間 (B) RPO 的定義與組織執行備份的頻率與方式息息相關 (C) RPO 定義的時間愈短，組織所需投入的成本就愈高 (D) RPO 屬持續營運計畫中需被考量與定義的項目之一
B	35. 下列何者技術可保護資料傳輸過程安全？ (A) 身分驗證 (B) 加密 (C) 電子簽章 (D) 雜湊函數
A	36. 請問可恢復系統功能或檔案資料，但其缺點是耗時較久之資料備份方式是指下列哪一種？ (A) 完全備份（Full Backup） (B) 巨量備份（Bigdata Backup） (C) 差異備份（Differential Backup） (D) 增量備份（Incremental Backup）

初級資訊安全工程師能力鑑定樣題

科目 2：資訊安全技術概論

第 7 頁，共 9 頁

C	37. 請問下列哪個議題非屬保護資料安全範圍？ (A) 某報名網站因 SQL Injection 弱點導致遭駭客取得會員資料 (B) 線上購物系統因駭客入侵導致客戶資料外洩 (C) 訂票系統因大量訂單湧入而當機 (D) 某學校教學系統遭人竄改分數
D	38. 在一個組織或安全網域內，相關的資訊系統須有一致性的同步時脈(鐘訊同步)，其主要的目的為何？ (A) 確保作業系統的完整性 (B) 防範資料的漏失 (C) 為了系統作業的方便 (D) 確保稽核日誌的準確性，以便紀錄事件與生成證據
A	39. 請問主要記錄系統程式所有活動行為，例如主機或伺服器發生異常活動狀況等，是指下列哪個紀錄檔之功能？ (A) 系統日誌檔 (B) 應用程式日誌檔 (C) 安全性日誌檔 (D) 網路日誌檔
C	40. 請問若某公司的系統管理員，將所有稽核日誌存放於另一台獨立的日誌伺服器 (Log Server)，並指派非管理系統之專人管理該伺服器，其最重要的目的為？ (A) 方便加密 (B) 確保機密不外洩 (C) 保護日誌 (D) 降低資安事件發生時的處理時間
A	41. 許多公司會將不同設備的日誌 (Log) 蒐集到同一個平台進行管理，但因為不同設備之日誌格式、命名方式不盡相同，此時為了方便分析，通常會對這些日誌進行什麼處理？ (A) 正規化 (Normalization) (B) 去識別化 (De-identification) (C) 最佳化 (Optimization) (D) 初始化 (Initialization)
D	42. 關於雙因素認證常見的媒介，下列敘述何者不正確？ (A) Email (B) 簡訊 (C) 智慧卡 (D) 密碼

初級資訊安全工程師能力鑑定樣題

科目 2：資訊安全技術概論

第 8 頁，共 9 頁

D	43. 在建立雲端服務所需資料庫時，從資訊安全的角度來看，以下事項何者較不需要被注意？ (A) 資料加密 (B) 資料庫使用者角色控管 (C) 對連線來源控管 (D) 使用正規化規劃資料庫
B	44. 在建置雲端資訊系統時，常會對系統進行一系列的安全分析，請問下列何者不屬於安全分析？ (A) 弱點分析（Vulnerability Analysis） (B) 可行性分析（Feasibility Analysis） (C) 威脅分析（Threat Analysis） (D) 風險評估（Risk Analysis）
A	45. 請問在行動裝置上，下列何種的使用者驗證方式安全性最低？ (A) 圖形軌跡鎖 (B) 人臉辨識鎖 (C) 指紋辨識鎖 (D) 虹膜辨識鎖
B	46. 在使用行動裝置時，下列何者攻擊手法主要是針對人與人的互動形成的？ (A) 重送攻擊（Replaying Attack） (B) 社交攻擊（Social Engineering） (C) 中間人攻擊（Man in the Middle Attack） (D) 阻斷式服務攻擊（Denial-of-Service Attack）
D	47. 在行動裝置使用上，為避免使用者遭受網路釣魚攻擊（Phishing）所需注意的事項。下列敘述何者不正確？ (A) 輸入重要資訊時須觀察網址是否異常 (B) 勿胡亂開啟來路不明的信件連結 (C) 不隨意連接不信賴的 Wi-Fi 熱點 (D) 用無痕跡的瀏覽器開啟網頁
C	48. 為了確保「物聯網」的使用安全，使用者應該採取哪些防範措施？ (1) 啟用智慧型設備上建議的安全功能 (2) 採用 WiFi 通訊技術就可以確保資料傳輸的安全 (3) 購買會定期更新產品韌體的廠商所推出的物聯網產品 (4) 使用安全的密碼 (A) (1), (2), (3) (B) (1), (2), (4)

初級資訊安全工程師能力鑑定樣題

科目 2：資訊安全技術概論

第 9 頁，共 9 頁

	(C) (1), (3), (4) (D) (2), (3), (4)
C	49. 關於 IoT 安全設計開發階段之安全建議，下列敘述何者不正確？ (A) 開發設計階段，將 IoT 採用高強度的密碼，並且強制啟用 (B) 開發設計階段，採用最新安全的作業系統，確保漏洞已經修補 (C) 開發設計階段，採用經濟實惠的硬體裝置節省成本 (D) 開發設計階段，製造商須提供系統故障中斷的應變機制
D	50. 在多個物聯網裝置組成的網路中，攻擊者控制了其中一個節點並將傳送至此節點的所有封包全部丟棄，請問以上敘述屬於下列哪種攻擊手法？ (A) 黑函攻擊 (B) 分割攻擊 (C) 蟲洞攻擊 (D) 黑洞攻擊

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 1 頁，共 12 頁

單選題 50 題（佔 100%）

C	1. 有關阻斷服務攻擊（DoS 攻擊）之敘述，下列何者正確？ (A) 攻擊者偽造傳輸層封包來破壞網路的攻擊行為 (B) 攻擊者使用惡意軟體在設備上執行未經授權的攻擊行為 (C) 攻擊者向目標伺服器發送大量請求，使其無法處理其他請求的攻擊行為 (D) 攻擊者使用偽造的電子郵件來詐騙用戶的攻擊行為
B	2. 下列何項行為最容易導致 OWASP Top 10 的 A01:2021-Broken Access Control 漏洞發生？ (A) 使用強密碼進行身份驗證 (B) 未在頁面上實施權限控制 (C) 在密碼重置流程中使用多重身份驗證 (D) 定期進行安全漏洞掃描與修復
B	3. 隨著無線網路盛行，在伺服器與客戶端之間放置雙方都無法察覺的軟體進行攔截、備份、竄改資料等動作會再傳送給接收方的是下列何種攻擊手法？ (A) 重放攻擊 (B) 中間人攻擊 (C) 網路釣魚 (D) 社交工程
A	4. 校園網路屬於下列何種網路類型？ (A) 區域網路（Local area network，LAN） (B) 廣域網路（Wide Area Network，WAN） (C) 網際網路（Internet） (D) 個人區域網路（Personal Area Network，PAN）
A	5. 在 OSI（Open System Interconnection Model）的參考模型中，諸如 Chrome、Firefox 等瀏覽器軟體應該屬於下列何項層次？ (A) 應用層（Application Layer）

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 2 頁，共 12 頁

	(B) 網路層 (Network Layer) (C) 資料連結層 (Data Link Layer) (D) 傳輸層 (Transport Layer)
C	6. 下列何項網路設備可以找出傳送封包的最佳路徑？ (A) 中繼器 (B) 橋接器 (C) 路由器 (D) 集線器
D	7. 請問 DNS 放大攻擊 (DNS Amplification Attacks)，最屬於下列何種網路攻擊？ (A) 病毒 (B) 木馬 (C) 蠕蟲 (D) 阻斷服務攻擊
C	8. 建置虛擬私有網路 (Virtual Private Network, VPN) 的主要目的是下列何項？ (A) 加速網路連接，增加下載檔案的速度 (B) 增加網站流量，創造瀏覽次數 (C) 保護網路傳輸的資料安全 (D) 阻擋廣告，避免廣告消耗網路頻寬
A	9. 關於通訊埠 (Port) 預設端口的敘述，下列何項錯誤？ (A) SFTP，通訊埠 21 (B) RDP 為遠端桌面，通訊埠 3389 (C) HTTP，通訊埠 80 (D) DNS，通訊埠 53
A	10. 有關防火牆進行封包過濾時所考慮之因素，下列描述何者最「不」適切？ (A) 僅考慮封包的目的位址 (B) 封包的協定 (C) 封包的連接埠編號

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 3 頁，共 12 頁

	(D) 封包的網路界面
B	11. 有關 TCP/IP (DoD) 模型之敘述，下列何者有誤？ (A) 包含應用層 (Application Layer) (B) 包含會談層 (Session Layer) (C) 包含網際網路層 (Internet Layer) (D) 包含網路存取層 (Network Access Layer)
C	12. 當企業有大量的內部網址時，會自行架設 DNS Server，如果 DNS Server 的需求量較高，可能需要建置多台 DNS Server 互相備援，並且使用一個特定功能來傳輸各台 DNS Server 彼此的 DNS Record，讓每一台 DNS Server 的紀錄都保持一致。但是如果該功能沒有限制存取來源，可能會導致任意使用者都可以透過該功能直接跟企業的 DNS Server 索取該企業全部的 DNS Record，造成內部的網址外流。請問下列何項就是上述的特定功能？ (A) DNS Tunneling (B) DNS Amplification (C) DNS Zone Transfer (D) DNS Spoofing
A	13. 下列哪一個通訊協定沒有經過加密傳輸，直接採用明文的方式傳輸，有機會被攻擊者竊聽？ (A) TELNET (B) FTPS (C) HTTPS (D) SSH
A	14. 下列何者可以用來評估作業系統 (Operation system) 的安全性最為適切？ (A) Common Criteria (B) ISO/IEC 27001 (C) IEC 62443-2-1 (D) Cybersecurity Framework
B	15. 關於 Rootkit 和 Bootkit 的敘述，下列何項最「不」適切？ (A) Rootkit 是一種惡意軟體，用於隱藏攻擊者對操作系

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 4 頁，共 12 頁

	統的控制權 (B) Rootkit 的偵測防禦容易，因為它易被防毒軟體發現 (C) Bootkit 是一種惡意軟體，與 Rootkit 類似，但是它是安裝在操作系統的引導（boot）區塊，以實現在操作系統啟動之前攻擊的目的 (D) 與 Rootkit 一樣 Bootkit 可以隱藏攻擊者的存在和攻擊行為，例如隱藏進程、檔案、目錄、登錄項目、網路連接等等，從而繼續控制和攻擊受害者系統
B	16. 常見作業系統安全管理，下列何項敘述是錯誤的？ (A) 導入政府組態基準（Government Configuration Baseline, GCB）強化作業系統安全 (B) Administrator 帳戶建議開啟 (C) Guest 帳戶建議停用 (D) 建議設定帳戶鎖定閾值（嘗試登入錯誤次數）：5 次以下不正確的登入嘗試，但須大於 0 次
D	17. 在攻擊者已經取得系統存取權限之後，除了翻找系統有沒有高權限帳號的密碼或是嘗試破解雜湊之外，也可能會利用已知的提升權限弱點來讓自己變成 root 或 Administrator，以便取得更完整的系統控制權。請問下列何項「不」是 Windows 或 Linux 作業系統常見用來提升權限的弱點或技巧？ (A) Dirty COW (B) SetUID (C) Juicy Potato (D) Chisel
B	18. 下列何者是微軟網路芳鄰會使用到的 port？ (A) TCP 248 (B) TCP 445 (C) TCP 80 (D) TCP 20
D	19. 關於 SQL Injection 攻擊及其防範的敘述，下列何者錯誤？ (A) SQL Injection 攻擊主要是利用應用程式撰寫上的疏

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 5 頁，共 12 頁

	忽，使得執行非預期的 SQL 指令，非法存取資料庫中的內容 (B) SQL Injection 攻擊所採用之攻擊方法，是一種利用未做好輸入查驗（Input Validation）所衍生的問題 (C) 發生 SQL Injection 攻擊最大的原因，在於未對輸入文字進行過濾，未作完善的輸入條件檢查 (D) 關於 SQL Injection 攻擊之預防拒絕輸入單引號、雙引號、分號等特殊字元即可
A	20. 為避免資料庫被入侵攻擊，下列何種處理方式最適合？ (A) 應用系統採用多因素身份驗證機制進行設計，可確保應用程式對資料庫存取身分 (B) 不用定期更新資料庫軟體版本，因為會影響程式相容性 (C) 資料庫中的敏感資料不用加密，以提升效能 (D) 資料庫多在內網，十分安全不需監視資料庫活動
D	21. 下列何種攻擊手法是透過瀏覽器執行攻擊者插入到網頁中的 Script 指令，來竊取使用者輸入的資料？ (A) 緩衝區溢位攻擊（Buffer Overflow） (B) 釣魚攻擊（Phishing） (C) 阻斷服務攻擊（DoS） (D) XSS 攻擊（Cross-Site Scripting）
C	22. 依據 OWASP Top 10 有關應用程式未驗證或過濾使用者所提供資料而產生風險之敘述，下列何者有誤？ (A) 常見的攻擊手法包含 Cross-site Scripting 攻擊 (B) 常見的攻擊手法包含 SQL Injection 攻擊 (C) 需要將命令與查詢資料合併，以防止注入式攻擊 (D) 屬 OWASP Top 10 的 Injection 風險
B	23. 在 IP camera 使用時，要做下列何項串流的安全傳輸協定以避免攻擊？ (A) SMTPS

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 6 頁，共 12 頁

	(B) RTSPS (C) SFTP (D) RDP
C	24. 網站應用程式中的元件存在弱點，若要有效避免遭受攻擊者利用的改善措施，下列何者錯誤？ (A) 移除不必要的元件、功能或檔案 (B) 持續盤點用戶端與伺服器端元件的版本，並確認是否含有漏洞 (C) 僅從官方網站與知名論壇取得相關元件 (D) 監控已無維護的元件，可透過虛擬修補（Virtual Patch）降低受駭風險
D	25. 關於安全的實做密碼重設功能的敘述，下列何者錯誤？ (A) 避免使用密碼問題來確認為其為本人 (B) 不可儲存使用者重新設定之密碼明文 (C) 密碼重設後，應自動登出該帳號既有連線 (D) 應發送通知並附上密碼供本人確認修改內容
C	26. 關於應用程式安全的描述，下列何者最「不」適切？ (A) 應用程式弱點掃描可以瞭解是不是有既有的技術性弱點 (B) 應用程式碼的掃描可及早偵測程式撰寫的問題及可能產生的安全性問題 (C) 模糊測試（Fuzzing）指自動產生程式碼到原始程式中，以偵測程式碼的問題 (D) 應用程式的業務邏輯問題需要由熟悉業務的測試人員仔細的核實確認
C	27. 下列何項「不」是程式碼開發所使用的原始碼檢測工具（Static Code Analysis，SCA）？ (A) Fortify (B) Checkmarx (C) Nessus (D) SonarQube

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 7 頁，共 12 頁

D	28. 下列何項「不」是 C 程式語言常見的漏洞？ (A) Buffer Overflows (B) String Manipulation (C) Integer Overflow (D) SQL Injection
A	29. 下列何者「不」是用在分析了解惡意程式或作為弱點管理的服務及工具？ (A) archive.org (B) VirusTotal (C) ANY.RUN (D) vx-underground.org
B	30. 當上網時，防毒軟體跳出提示告知不明的項目，你不知道軟體來源，但又怕誤刪重要的檔案，請問應該優先採取下列何項的處理方式？ (A) 允許執行 (B) 隔離可疑項目 (C) 移除可疑項目 (D) 更新病毒碼
A	31. 下列何種惡意程式可以自己存在不需要寄生在其他的程式與檔案中，而且可以自己複製、自行在網路上傳播？ (A) 蠕蟲 (B) 木馬 (C) 邏輯炸彈 (D) 病毒
A	32. 面對勒索軟體檔案加密的威脅，業界採用多重備份來事前預防。關於業界常用的「3-2-1 備份原則」的描述，下列何正確？ (A) 3 是指三份備份、2 是指兩種不同儲存媒體、1 是指一份異地保存 (B) 3 是指三個單位核准、2 是指兩個主管確認、1 是指一個人員備份

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 8 頁，共 12 頁

	(C) 3 是指三級單位執行、2 是指二級單位確認、1 是指一級單位稽核 (D) 3 是指三種備份技術、2 是指二種備份流程、1 是指一個備份人員
C	33. 與防範惡意軟體有關議題，下列何項描述最「不」適切？ (A) 教育訓練所有的使用者對惡意軟體的基本知識，是最重要的防範方式 (B) 單純安裝惡意程式偵測軟體，通常不足以防範，系統存取權限與變更管理流程亦需加強 (C) 於作業系統中安裝應用程式的管理，黑名單比白名單的授權方式，對系統管理者更為有效 (D) 公司內網存取的實作控制措施，白名單的管控對預防惡意網站的攔阻更為有效
D	34. 關於數位版權管理（Digital rights management，DRM）的敘述，下列何者最「不」適切？ (A) DRM 是資料保護的一種方法 (B) DRM 是一系列存取控制技術，通常用於控制數位內容和裝置在被銷售之後的使用過程 (C) DRM 可控制使用者存取裝置和使用內容的方式 (D) NFT 技術可相容於現有所有的 DRM 技術
D	35. 如附圖所示，分析圖中非明文字串，所使用的加密、雜湊或編碼方式，下列敘述何項正確？ SG93IGRvIHlvdSBlbmNvZGUgb3lgZGVjb2RlIGJhc2U2NCBzdHJpbmc/Cg== (A) SHA3 (B) NetNTLMv2 (C) AES-128 (D) Base64
C	36. 關於資料備份流程的描述，下列何項正確？ (A) 資料備份於同機房其他設備保留一份，即可滿足備

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 9 頁，共 12 頁

	份要求 (B) 工具排程備份若有失敗狀況，因為隔天還會進行，不需要手動重新備份 (C) 備份結果須於可回復的設備，定期進行完整還原測試 (D) 依照內部提供的容量資源，決定保留代數
D	37. 關於系統通行碼管理的描述，下列何項最「不」適切？ (A) 應用系統通行碼選用，不應以鍵盤字母排列方式進行 (B) 通行碼於原始碼或資料庫中顯示，皆不適以明碼方式儲存 (C) 於資訊安全事故發生後，系統通行碼應於必要時要求強制變更 (D) 為了資訊安全上考量，通行碼長度應越短越適宜
D	38. 某公司於每日的凌晨 1 點進行備份，每週日進行完整備份（Full Backup），其餘各日進行增量備份（Incremental Backup），假設需要還原至週三下班時的狀況，需要下列何項備份檔案才能完成這樣工作？ (A) 該週日的備份即可 (B) 該週三的備份即可 (C) 該週日、一、二、三等 4 份的備份檔案 (D) 該週日、一、二、三、四等 5 份的備份檔案
C	39. 關於安全性資訊與事件管理（SIEM）的敘述，下列何者較「不」適切？ (A) SIEM 結合了安全相關的資訊管理及事件管理 (B) SIEM 用途包含偵測攻擊 (C) SIEM 不會有誤報與誤判的問題 (D) SIEM 側重於日誌的集中式管理和審計
C	40. 公司的官網受到駭客入侵，必須從官網 IIS Log File 來追蹤駭客來源以及手法，關於 IIS Log File 的敘述，下列何者錯誤？ (A) IIS 預設 log 路徑為

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 10 頁，共 12 頁

	%SystemDrive%\inetpub\logs\LogFiles\ (B) IIS 如果有多個網站 網站的 log 會在資料夾中以 u_exyymmdd.log 的 log 檔呈現 (C) 在預設狀態下，IIS 預設的日誌時間與台灣時間是一致的 (D) IIS 提供了 4 種日誌檔格式 (1) IIS 紀錄檔格式、 (2) NCSA 紀錄檔案格式、(3) W3C 紀錄檔格式、 (4) 自定義日誌檔案格式
D	41. 入侵偵測與防禦系統 (Intrusion Detection and Prevention Systems, IDPS) 可以主動反應偵測到的威脅，下列敘述何項最「不」適切？ (A) 發出入侵警告訊息 (B) 記錄入侵事件 (C) 可即時阻擋所偵測到的威脅 (D) 將入侵者引導到 DMZ (Demilitarized Zone) 區
B	42. 下列何項為應用系統日誌管理的主要目的？ (A) 加速系統的運作 (B) 用於故障排除、合規性記錄、支援威脅檢測、安全性問題確認等目的 (C) 監控系統用戶的操作 (D) 監督系統運用的效能
C	43. 某系統管理員查看一 RFC 5424 協定的記錄時，其 PRI (Priority Value) 為 165，請問下列個描述較為正確？ (A) Facility 可能是 kernel messages (B) Facility 可能是 NTP subsystem (C) Facility 可能是 local use x (D) Severity 可能是 Emergency: system is unusable
D	44. 依照雲端運算聯盟 (Cloud Security Alliance, CSA) 於 2019 年 8 月發表雲端運算面臨十一大安全威脅報告中，請問沒有使用強密碼是下列何種安全威脅？

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 11 頁，共 12 頁

	(A) 資料外洩 (Data Breaches) (B) 配置錯誤和變更控制不足 (Misconfiguration and inadequate change control) (C) 缺乏雲端安全架構和策略 (Lack of cloud security architecture and strategy) (D) 驗證密碼控制機制不足 (Insufficient identity, credential, access and key management)
D	45. 依照雲端運算聯盟 (Cloud Security Alliance, CSA) 發表的「雲端運算關鍵領域安全指南」，下列針對雲端運算的安全問題的敘述何者錯誤？ (A) 資料外洩是雲端運算安全的重大威脅，像是蘋果 iCloud 用戶洩密事件 (B) 資料遺失影響企業與客戶間的信任關係 (C) 安全性差的 API 會讓企業面臨機密性、完整性、可用性和歸責性的安全問題 (D) 雲端服務的安全防禦部署分散，若服務遭受攻擊不會影響整體環境
A	46. 行動裝置特別重視資料保護，下列敘述何者錯誤？ (A) 使用行動裝置雲端服務 (如：Google Drive、iCloud...等)，是大型雲端服務公司安全有其保障，可將資料傳送到雲端空間 (B) 廢棄行動裝置，應完整清除其上所有資料，並回復為行動裝置之出廠設定 (C) 不使用藍芽功能以進行無線耳機、無線鍵盤或檔案傳輸連結時，應將其關閉 (D) 不使用 NFC 功能，應將其關閉或遮蔽
C	47. 依照歐盟網路安全局 (European Union Agency for Cybersecurity, ENISA) 所發佈關於智慧型手機的十二項安全風險，請問透過偽造的 Apps、簡訊 Mail，藉以騙取使用者的密碼是下列何項？

113 年度第 1 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 6 月 1 日

第 12 頁，共 12 頁

	(A) 網路雍塞 (Network Congestion) (B) 資料外洩 (Data Leakage) (C) 釣魚行為 (Phishing) (D) 自動撥號 (Automatic Dialing)
C	48. 關於行動裝置的安全保護措施，下列敘述何者錯誤？ (A) 軟體下載與使用應該檢視權限的要求，確保沒有資料外洩的風險 (B) 軟體應自動或定期手動安裝更新修補程式 (C) 資安威脅不會影響行動裝置的電池壽命 (D) 行動裝置管理系統 (Mobile Device Management, MDM) 會限制行動裝置的行為，甚至可以遠端變更與清除行動裝置的內容
A	49. 知名的 Mirai 惡意程式針對物聯網設備進行感染後，可透過攻擊者控制發動 DDoS，請問主要是下列何項原因造成物聯網設備被感染？ (A) 預設的設定與密碼 (B) 低運算力 (C) 設備量大 (D) 持續連網
A	50. 關於物聯網的資安指引必須確立物聯網的裝置、系統、服務提供的安全性。相較一般 IT 設備，對於物聯網的設備描述何者「不」正確？ (A) 物聯網的設備牽扯隱私或是人生安全的要求比較不敏感 (B) 物聯網的軟硬體設備資源較缺乏且受限制 (C) 物聯網的設備缺乏穩定且有效的機制，且受限於硬體必須執行輕量化的演算法 (D) 物聯網的設備數量龐大且異質化的系統導致安全性不易維持

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 1 頁，共 14 頁

單選題 50 題 (佔 100%)

D	1. 有關防止 OWASP Top 10 的 A02:2021-Cryptographic Failures 漏洞之敘述，下列何者錯誤？ (A) 確保將所有的機敏資料加密 (B) 使用最新版且標準的強加密演算法 (C) 使用適當的金鑰管理 (D) 使用 HTTP 的協定加密傳輸中的資料
D	2. 下列何項「不」是過濾型網路防火牆所過濾的網路封包參數？ (A) 來源端 IP Address (B) 目的端 IP Address (C) 來源端 TCP/UDP Port (D) 目的端 MAC Address
C	3. 下列何項是正確的防火牆策略設定機制？ (A) 經適當的申請流程後即可無限期使用 (B) 保護服務主機的防火牆，可預設允許由主機連出 internet 的連接 (C) 防火牆策略應由受過專業訓練的人員審核及設定 (D) 「黑名單」的設定方式優於「白名單」
B	4. 在殭屍網路 (Botnet) 的架構中，攻擊者通常會將惡意軟體散佈到多台受害者電腦上，將這些受感染的電腦轉變為「殭屍電腦」。當攻擊者累積足夠數量的殭屍電腦後，通常會透過一台「中介主機」來下達指令，進而發動對特定目標的網路攻擊。請問下列何項是這種中介主機的專有名稱？ (A) SQL 伺服器 (B) C&C (Command and Control) 伺服器 (C) DNS (Domain Name System) 伺服器 (D) FTP (File Transfer Portocal) 伺服器

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：II2 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 2 頁，共 14 頁

D

5.

附圖為防火牆的過濾規則表及封包資訊。在判斷封包是否通過防火牆時，請根據規則表來決定並選擇正確的選項。請問該封包依據防火牆規則是否通過，以及符合哪條規則？

防火牆過濾規則表

規則	來源 IP 位址	目的 IP 位址	類型	來源埠編號	目的埠編號	結果
1	20.210.21.72	*	*	*	*	拒絕
2	140.130.149.*	140.112.*	TCP	*	23	通過
3	140.112.*	140.130.149.*	TCP	23	*	通過
4	140.*	140.*	TCP	*	25	通過
5	*	*	*	*	*	拒絕

封包資訊：

來源 IP 位址：120.132.78.54

目的 IP 位址：140.130.149.60

封包類型：UDP

來源埠編號：1692

目的埠編號：53

(A) 通過，符合規則 1

(B) 通過，符合規則 3

(C) 通過，符合規則 4

(D) 被拒絕，符合規則 5

C

6.

關於網路安全敘述，下列何者較「不」適當？

(A) 網路安全包含：網路裝置安全、網路資訊安全、網路軟體安全

(B) 駭客可透過網路的入侵來達到竊取敏感資訊的目的

(C) 好的網路安全設計只需要單層防護即可

(D) 開啟電子郵件時，相關附件或連結務必小心判別

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 3 頁，共 14 頁

B	7. 在釣魚攻擊中，攻擊者通常會使用下列何種方式來欺騙受害者？ (A) 直接入侵受害者的電腦 (B) 假冒合法機構發送電子郵件 (C) 利用病毒感染受害者的系統 (D) 竊取網路流量
B	8. 下列哪一種攻擊手法是利用「不」安全的無線網路來竊取資料？ (A) 拒絕服務攻擊 (Denial of Service, DoS) (B) 中間人攻擊 (Man-in-the-Middle attack, MITM) (C) 跨站腳本攻擊 (Cross-Site Scripting, XSS) (D) SQL 注入攻擊 (SQL Injection)
A	9. 有關 OSI 模型中會議層 (Session Layer) 之敘述，下列何者正確？ (A) 主要的功能是負責管理和控制不同應用程式之間的對話 (B) 確保資料傳輸的可靠，並處理錯誤復原 (C) 處理封包的路由與轉發 (D) 將資料進行壓縮與解壓縮以提高傳輸效率
C	10. 下列哪一種攻擊行為屬於 OSI 第七層 (應用層) 的 DDoS 攻擊手法？ (A) SYN Flood Attack (B) Fragmentation Attack (C) HTTP Flood Attack (D) UDP Flood Attack
A	11. 在通訊安全中，「完整性」指的是下列何項？ (A) 確保數據資料在傳輸過程中未被未經授權的修改 (B) 確保網站的可用性，可隨時存取網站 (C) 確保所有使用者都有依最小原則設定權限 (D) 確保網絡傳輸速度與申請速率相符

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 4 頁，共 14 頁

A	12. 在通訊安全中，端對端加密（End-to-End Encryption, E2EE）的意思是下列何項？ (A) 數據資料在傳輸過程中始終被加密 (B) 只有發送端可以解密數據資料 (C) 數據資料在加密設備上加密，然後傳輸 (D) 數據資料在傳輸過程中不會被加密
B	13. 在防火牆的深度封包檢查（Deep Packet Inspection, DPI）技術中，下列哪一項是其主要目的？ (A) 僅檢查封包的標頭資訊 (B) 分析封包的內容以識別應用層協定和潛在威脅 (C) 僅過濾基於 IP 位址的流量 (D) 提供使用者身份驗證功能
A	14. 當電腦 A 位於防火牆 B 後面，只想要開放電腦 A 上的遠端桌面服務，供外部使用者可以從網際網路連線進入時，防火牆 B 應該設定下列何種功能最合適？ (A) Port Mapping (B) Virtual Server (C) DHCP (D) DNS
B	15. 關於 Linux 檔案的敘述下列何者錯誤？ (A) /etc/shadow：儲存使用者密碼的 Hash 值 (B) /bash_history：使用者登入的歷史紀錄 (C) /var/log/secure：檔案用於記錄與安全相關的所有事件，包含使用者登入紀錄 (D) /.ssh/known_hosts：記錄對方連線主機的指紋資訊

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 5 頁，共 14 頁

C	16. 某網站存在跨站請求偽造（Cross Site Request Forgery, CSRF）漏洞，攻擊者可能會利用該漏洞發起攻擊。下列何種方法最常用來防止 CSRF 攻擊？ (A) 在 URL 中加入 Session ID (B) 將所有表單設為唯讀權限（Read only） (C) 在使用者的請求中加入 Token (D) 將所有網頁設置為不可被搜索引擎索引
D	17. 在網路中，路由器（Router）是一種常見的網路硬體設備。下列何項是路由器的主要功能？ (A) 分配 IP 位址給網路中的裝置 (B) 在區域網路（LAN）中將資料封包轉送到正確的裝置 (C) 為網路中的所有資料封包加密 (D) 負責將資料封包從一個網路轉送到另一個網路
C	18. 關於 Linux 作業系統中檔案權限的敘述，下列何者正確？ (A) 檔案是否刪除，依據的權限值為檔案的 write 權限值 (B) 只要是副檔名為.exe 的二進位檔案，均可執行 (C) 檔案是否可以被使用者新增，需看該檔案所在的工作目錄是有給予使用者 write 權限 (D) root 使用者不可刪除一般使用者 home 目錄
B	19. 依據 OWASP Top 10 有關安全配置錯誤風險之敘述，當應用程式處於以下何種狀態時，該應用程式可能容易受到攻擊？ (A) 啟用或安裝了必要的功能 (B) 預設帳號及密碼仍處於啟用狀態 (C) 系統最新的安全功能被啟用 (D) 伺服器發送安全標頭或指令

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 6 頁，共 14 頁

C	20. PHP 程式語言中有好幾個可以用來執行作業系統指令的危險函數，使用的時候必須非常謹慎，如果程式撰寫不當，有機會被攻擊者拿來利用，進一步取得網頁伺服器的控制權。請問下列哪一個語法不是用來執行作業系統指令的 PHP 函數？ (A) system (B) passthru (C) eval (D) popen
C	21. 作業系統在更新軟體、韌體時，下列敘述何者錯誤？ (A) 可以透過 Hash 確認完整性 (B) 可以在測試機先做升級測試 (C) 看到升級提醒信件可以直接進行升級 (D) 同時可以更新 SBOM (Software Bill of Materials) 清單
C	22. 下列哪一種攻擊手法會利用應用程式的權限設定不當，讓攻擊者取得對應用程式或作業系統的未授權存取，並可能進一步提權成為系統管理員？ (A) 點擊劫持攻擊 (Clickjacking) (B) 旁通道攻擊 (Side-channel Attack) (C) 特權提升攻擊 (Privilege Escalation) (D) 特洛伊木馬攻擊 (Trojan Horse)
D	23. 要管理好資料庫系統，除了對資料庫系統有深度認知之外，仍需要了解資料庫系統所面臨的安全威脅。下列何項較「不」屬於資料庫系統所面臨的安全威脅？ (A) 資料庫內資料外洩 (B) 資料庫內的資料遭非法篡改與偽造 (C) 資料庫推論 (Database Inference) (D) 資料庫管理人員不具有作業系統操作認證

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 7 頁，共 14 頁

D	24. 軟體組成分析 (Software Composition Analysis, SCA) 主要是針對程式設計的哪一個部分進行分析？ (A) 所開發的原始碼是否有設計缺陷 (B) 編譯後的執行檔是否有錯誤配置 (C) 針對二進位檔進行 Security Hardening 檢查 (D) 軟體元件是否有已知漏洞
B	25. 若想要針對駭客反組譯程式的威脅，下列何者較「無法」達到有效保護？ (A) 執行檔加密保護 (B) 遵循程式碼安全開發指引 (C) 程式碼混淆 (D) 二進制檔案加殼保護
C	26. 當資料庫洩漏時，儲存在其中的使用者密碼，使用下列何種機制較「不」容易被輕易破解？ (A) 使用明文儲存密碼 (B) 使用對稱加密儲存密碼 (C) 使用加鹽式 (Salt) 雜湊函數後儲存密碼 (D) 使用 Base64 編碼儲存密碼
B	27. 黑箱測試是軟體開發常見的安全檢測方式。下列何項「不」是黑箱測試的特性？ (A) 檢測人員不需要具備應用程式開發知識與經驗 (B) 檢測人員必需知道該受測軟體內部結構，以利測出正確結果 (C) 檢測人員僅須從使用者角度，進行軟體介面、功能及外部結構進行測試 (D) 檢測人員必須利用有效輸入與無效輸入來驗證是否有正確的輸出結果

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 8 頁，共 14 頁

C	28. DevSecOps 是軟體開發過程中，每個階段整合安全測試的實務，它是 DevOps 實務的延伸。請問下列何項「不」包含在 DevSecOps 所定義的文化內容？ (A) 開發 (B) 安全性 (C) 規劃 (D) 營運
C	29. 軟體開發者設計的維護通道，被駭客利用程式存在的漏洞進出系統或網路，此攻擊模式稱為下列何項？ (A) 通道密碼攻擊 (B) 窮舉攻擊 (C) 後門攻擊 (D) 中間人攻擊
C	30. 請問下列哪一項防護措施是主要針對惡意程式的防護方法？ (A) 將所有電腦系統與網路斷開連接，避免受到外部攻擊 (B) 定期備份重要資料，防止資料遺失 (C) 安裝防毒軟體，並定期更新病毒碼 (D) 僅下載來自知名網站的檔案，避免受到釣魚攻擊
B	31. 下列哪一種密碼雜湊的強度最高、破解速度非常慢，即使用常見的密碼破解軟體 hashcat 來進行破解，也需要耗費非常久的時間才能破解出來？ (A) NTLM (B) bcrypt (C) MD5 (D) SHA1

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 9 頁，共 14 頁

D	32. 對惡意程式的管理方式，下列何項正確？ (A) 系統已安裝防範惡意程式偵測的軟體，不需要定期再執行掃描 (B) 定期蒐集到對系統軟體的威脅情資，無法做為防範惡意程式的來源依據 (C) 已於系統中安裝偵測惡意程式的防毒軟體，經由網路取得的資訊，使用前不需要額外進行掃描 (D) 定期實施社交工程測試，也是針對防範惡意軟體認知的提升
B	33. 為了防止企業遭受勒索軟體攻擊而發生損害，下列敘述何者較「不」適當？ (A) 啟用端點防護軟體（Endpoint Protection），並定期更新病毒定義庫，可阻擋已知的威脅 (B) 將所有的備份資料移至雲端，以避免勒索軟體威脅 (C) 對所有員工進行資安意識訓練，讓其識別釣魚郵件及可疑的附件，並啟用多重要素驗證（Multi-factor authentication, MFA），可降低被滲透機會 (D) 設定網路分區隔離（Network Segmentation），限制不同網段間的通信，可減少破壞範圍
C	34. 關於備份管理的目的，下列敘述何者錯誤？ (A) 防止資料丟失 (B) 提高資料可用性 (C) 複雜資料復原過程 (D) 提高業務連續性

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 10 頁，共 14 頁

B	35. 請問下列何種備份策略，在還原時，只要當次備份的檔案及上一次完整備份檔案即可完成資料的還原？ (A) 完整備份配合增量備份 (B) 完整備份配合差異備份 (C) 複製 (D) 差異備份配合增量備份
B	36. 關於備份媒體管理的描述，下列何項有誤？ (A) 備份媒體需要依照資訊機密性及完整性為考量，使用密碼式技術保護 (B) 備份媒體若為磁帶時，可以永久保存資料 (C) 備份至雲端空間，也可做為備份的一種資源 (D) 備份媒體銷毀流程時，亦需考量資料重要性選擇銷毀方式
A	37. 某員工平常使用筆記型電腦處理其公司業務，電腦上存放有公司的重要資料，但因工作需求，常需攜帶電腦至公司以外的場所使用，基於保護公司資料安全的考量，沒有獲得額外授權或指示的情況下，請問下列何項措施較「不」合適？ (A) 將資料同步至員工私人的雲端空間 (B) 將資料同步至公司配發的的雲端空間 (C) 啟用 BitLocker (D) BIOS 設定開機密碼
B	38. 企業在進行資料備份時，下列哪一種做法最能確保備份資料的安全性及完整性？ (A) 將所有備份儲存在與原始資料相同的伺服器上 (B) 定期將備份資料存放至異地儲存空間 (C) 為了快速完成備份，只在重要文件發生變更時才進行備份 (D) 備份後立即刪除原始資料，以節省儲存空間

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 11 頁，共 14 頁

D	39. 關於 Linux 日誌的相關描述，下列何者錯誤？ (A) /var/log/boot.log 記錄開機時系統核心偵測與啟動硬體，及各種核心支援的功能啟動等，只存放當次開機的資訊 (B) /var/log/cron 記錄 crontab 排程有沒有實際被進行 (C) /var/log/dmesg 記錄系統在開機的時候核心偵測過程所產生的各項資訊 (D) /var/log/messages 記錄系統上面所有的帳號最近一次登入系統時的相關資訊
C	40. 關於日誌管理會收攏許多 Log 記錄的敘述，下列何者正確？ (A) Web 網站日誌只收集網站流量和使用者的資訊，無法用在效能調教或是駭客入侵鑑識 (B) 網頁應用程式防火牆安全日誌，可以收到駭客惡意攻擊的訊息，無法探測潛在的漏洞攻擊活動 (C) 應用程式日誌，除可以記錄應用程式的錯誤訊息，也有機會用於除錯與效能的調教 (D) 作業系統日誌，以 Windows Event Log 類型來說，只可以收集安全、應用程式、系統等三類型記錄，無法自定義相關日誌

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 12 頁，共 14 頁

B

41. 有效管理來自伺服器、網路設備及應用程式等各種來源的日誌資訊可以提升資料的安全性並檢測威脅。請問下列有關日誌管理的描述何者有誤？
(A) 不同網路設備的日誌格式不同，Windows Event Viewer 就沒辦法直接開啟 Linux 系統的日誌
(B) 依據「資通系統防護基準驗證實務」規定，日誌的保存期限至少為 3 個月
(C) 任何發生在機關資通系統中可觀察到行為之結果稱為資通系統事件，應當具備有記錄特定事件之功能，並決定應記錄之特定資通系統事件
(D) 日誌應記錄資通系統管理者帳號所執行之各項功能

B

42. 最近某工程師發現他的電腦十分緩慢，當其查看事件檢視器如附圖，請問從附圖中的資料，可以確認的結論為下列何項？

關鍵字	日期和時間	來源	事件識別碼	工作類別
稽核失敗	2024/4/9 下午 01:28:23	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:28:23	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:28:11	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:28:11	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:56	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:56	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:48	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:48	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:46	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:46	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:35	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:35	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:24	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:24	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:14	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:14	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:27:01	Microsoft Windows security auditing.	4776	認證驗證
稽核失敗	2024/4/9 下午 01:27:01	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:26:48	Microsoft Windows security auditing.	4625	登入
稽核失敗	2024/4/9 下午 01:26:48	Microsoft Windows security auditing.	4776	認證驗證

(A) 該電腦已經被入侵成功
(B) 有人嘗試登入該電腦，但都失敗
(C) 該電腦應該沒有問題
(D) 電腦中了木馬

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 13 頁，共 14 頁

D	43. 在日誌管理中，為了確保操作行為能被追蹤並歸責到特定使用者，下列哪一項做法較「不」適當？ (A) 使用唯一識別符碼，以確保使用者身份唯一 (B) 記錄每次操作的時間、使用者 ID 和具體動作 (C) 對所有事件，包括正常與異常行為，均進行詳細記錄 (D) 系統日誌的存取應妥善保護，並由最高權限的管理員帳戶維護管理
C	44. 企業若使用雲端服務作為企業資料的儲存，請問下列何項部屬模式更能確保機密性？ (A) 公有 (Public) 雲 (B) 自由 (Free) 雲 (C) 私有 (Private) 雲 (D) 混和 (Hybrid) 雲
C	45. 在雲端運算環境中，下列哪一項較「不」是常見的安全威脅？ (A) Distributed Denial of Service (DDoS) 攻擊 (B) API (應用程式介面) 的脆弱性 (C) 雲端實體主機的竊取 (D) 網路釣魚攻擊
B	46. 組織內員工可以使用個人擁有的智慧型手機或平板等行動裝置執行組織內的業務的狀況，可適應移動辦公趨勢，滿足現代行動化商務需求，其優點非常多，但不包括下列何項？ (A) 使用個人的行動裝置可以提高工作效率 (B) 個人裝置由個人保管，減少資料外洩的風險 (C) 減少組織購買設備的費用 (D) 組織透過行動裝置管理系統 (Mobile Device Management, MDM) 管理組織內的行動裝置，主要目的在於限制行動裝置可以從事的行為

113 年度第 2 次 資訊安全工程師能力鑑定能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：113 年 11 月 23 日

第 14 頁，共 14 頁

C	47. 行動裝置常被作為雙因子認證（Two-Factor Authentication, TFA）的認證因子之一，請問下列何項「不」是行動裝置常用的認證開機方式？ (A) 人臉辨識 (B) 指紋辨識 (C) RFID 辨識 (D) 圖形辨識
C	48. 保護行動裝置避免遭受惡意軟體的攻擊，下列何項對策較「不」適當？ (A) 時常掌握應用程式的使用者對 APP 的評價 (B) 定期更新行動裝置作業系統和應用程式 (C) 每天更改裝置的鎖定密碼 (D) 避免連接到公共 Wi-Fi 網路
A	49. 物聯網架構具有三個層次，包含感知層、網路層、應用層，分別應用於 Bluetooth、Wi-Fi、4G 的加密保護機制為下列何項？ (A) LE Encryption；WPA/WPA2；EEA（EPS Encryption Algorithm） (B) AES；LE Encryption；WEP (C) LE Encryption；WPA/WPA2；SNOW 3G (D) KASUMI；SNOW 3G；WPA-PSK/WPA2-PSK
C	50. 駭客常使用下列何種技術破解物聯網中 Wi-Fi AP 的 WPA2 密碼？ (A) SQL 注入攻擊 (B) 分散式拒絕服務（DDoS）攻擊 (C) 字典攻擊（Dictionary Attack） (D) 跨站腳本攻擊（Cross-Site Scripting, XSS）

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：II2 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 1 頁，共 15 頁

單選題 50 題 (佔 100%)

B	1. 網路防火牆的訪問控制列表 (Access Control List, ACL) 指的是下列何項？ (A) 列出所有使用者帳號 (B) 定義哪些流量可以通過防火牆 (C) 記錄網路活動 (D) 阻止惡意軟體
D	2. 有關 BadUSB 的敘述，下列何者正確？ (A) BadUSB 是一種惡意軟體，僅會感染 USB 隨身碟內的檔案資料 (B) BadUSB 攻擊僅限於 Windows 作業系統，不會影響 macOS 或 Linux (C) BadUSB 攻擊無法被一般的防毒軟體偵測並阻擋 (D) BadUSB 利用修改 USB 裝置的韌體，使其在電腦上被辨識為其他硬體裝置 (如鍵盤)
B	3. 下列哪一種攻擊手法主要是透過大量的請求來使目標系統無法正常運作？ (A) 魚叉式釣魚 (Spear phishing) 攻擊 (B) 阻斷式服務 (Denial of Service, DoS) 攻擊 (C) 中間人 (Man-in-the-Middle, MITM) 攻擊 (D) SQL 注入 (SQL Injection) 攻擊

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：II2 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 2 頁，共 15 頁

B	4. 在 SSL/TLS 通訊協定中，客戶端與伺服器會在握手階段（Handshake）交換金鑰與協定版本資訊。下列何項最能說明為什麼在握手過程中要同時交換「隨機數（Random Values）」與「Session ID」等資訊？ (A) 為了減少握手所需的封包傳輸次數，提升傳輸速率 (B) 為了確保金鑰獲取（Key Derivation）具有多樣性與不可預測性 (C) 為了讓伺服器能夠在握手過程中壓縮客戶端的傳輸內容 (D) 為了讓客戶端在握手後能夠複用過去的憑證（Certificate）而不再驗證
C	5. 當配置 DMZ（Demilitarized Zone）時，通常放置在該區域的伺服器是下列何項？ (A) 內部員工專用檔案伺服器 (B) 公司內部財務資料庫伺服器 (C) 需對外提供服務的 Web 或郵件伺服器 (D) 個人用電腦
C	6. 下列何者最能描述「ARP 詐騙（ARP Spoofing）」的攻擊手法？ (A) 改寫目標伺服器上的帳號密碼 (B) 竄改 DNS 伺服器的 IP 紀錄 (C) 竄改區域網路中 MAC 與 IP 對應 (D) 強行中斷 TCP 三向交握（Three-way Handshake）

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 3 頁，共 15 頁

D	7. 在資料完整性保護上，當使用雜湊函數（例如 SHA-256）進行訊息驗證時，下列哪種方法最能防止「長度延展攻擊（Length Extension Attack）」？ (A) 直接使用 SHA-256 雜湊結果作為簽章 (B) 使用常見的 MD5 雜湊函數來保護資料 (C) 在雜湊前對訊息加上高熵的隨機鹽值（Salt），並在驗證時同樣加入該鹽值 (D) 使用 HMAC（Hashed Message Authentication Code）機制進行驗證
C	8. 當突然發現區域網路中，有大量的電腦連線並傳輸不明的資料時，請問最有可能是下列何種網路攻擊？ (A) 分散式阻斷服務攻擊（Distributed Denial-of-service Attack，DDoS） (B) 中間人攻擊（Man-in-the-Middle Attack，MITM） (C) 蠕蟲（Worms） (D) 鍵盤側錄（Keylogging / Keystroke Logging）
C	9. 有關狀態檢視防火牆（Stateful Inspection Firewalls）以及封包過濾防火牆（Packet Filter Firewalls）之敘述，下列何者錯誤？ (A) 狀態檢視防火牆是基於 TCP/IP 協定特徵而發展出來的功能 (B) 狀態檢視防火牆使用「狀態表」來確認任何進入流量 (C) 封包過濾防火牆基於 OSI 模型的第 4 層-傳送層（Transport Layer）運作 (D) 封包過濾防火牆會針對 IP 封包的標頭加以檢查，藉以過濾掉非法封包

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 4 頁，共 15 頁

D	10. 在網路通訊中，數位憑證的主要作用是下列何項？ (A) 加速網路傳輸速度 (B) 過濾垃圾郵件 (C) 壓縮檔案大小 (D) 驗證通訊對象的身份
B	11. 在網路通訊中，中間人攻擊（Man-in-the-Middle Attack）的主要目的是下列何項？ (A) 癱瘓目標系統 (B) 竊取或竄改通訊內容 (C) 感染惡意程式 (D) 偽造 IP 位址
C	12. 關於通訊安全的敘述，下列何者錯誤？ (A) 當兩個系統進行通訊時，務必確保系統透過安全通道進行通訊，獲授權存取雙方使用共用資源 (B) 安全通訊端層（SSL）是對網際網路通訊提供隱私、驗證和整合性的安全性通訊協定 (C) SSL 是通道加密，資料也加密保護 (D) 傳輸層安全標準（TLS）是標準網際網路通訊協定，可以加密處理電子郵件，確保郵件在傳輸過程中安全不外洩
D	13. 下列何者是虛擬私人網路（Virtual Private Network，VPN）的主要功能？ (A) 過濾垃圾郵件 (B) 加速網路速度 (C) 防止病毒感染 (D) 隱藏 IP 位址，加密網路流量

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 5 頁，共 15 頁

B	14. 在作業系統安全防護中，為了降低勒索病毒（Ransomware）的影響，下列何種作法最為有效？ (A) 停用所有網路連線以阻止病毒傳播 (B) 定期備份重要資料，並存放於離線或雲端安全儲存空間 (C) 只安裝作業系統更新，不安裝應用程式更新 (D) 透過簡單密碼來保護系統，減少複雜性
B	15. 下列有關網路釣魚（Phishing）的敘述何者正確？ (A) 主要透過加密程式來加密受害者電腦中的檔案 (B) 通常利用社交工程手法，偽裝成可信賴的實體，誘使受害者提供敏感資訊 (C) 攻擊途徑只會發生在電子郵件中，無法在社交媒體或簡訊中發現 (D) 安裝並更新防毒軟體可完全阻止網路釣魚攻擊
D	16. 為強化 Windows 作業系統安全，使用者在維護作業系統運作穩定性並降低資安風險，採取下列何項是最有效的方式？ (A) 向原廠購買有效授權 (B) 購買硬體防火牆進行防護 (C) 維持網路連線速率與提昇連線品質 (D) 定期進行更新與修補漏洞
D	17. Linux 作業系統日常維運常見的資安防護方式中，下列何者最「不」適切？ (A) 安裝 ClamAV 防毒軟體 (B) 拒絕 root 使用者遠端登入系統 (C) 啟動 SELinux 強化安全機制 (D) 將 Linux 作業系統關機

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 6 頁，共 15 頁

B	18. 在管理非法軟體使用時，下列何項最能有效防止員工安裝未授權軟體？ (A) 允許員工自行安裝軟體，但定期進行系統掃描和審計以確保合規 (B) 採用應用程式白名單，僅允許經批准的軟體安裝並限制其他軟體執行 (C) 定期檢查已安裝軟體，並由 IT 部門手動移除未授權軟體 (D) 設置軟體下載和安裝警告系統，提醒員工遵守公司政策
D	19. OWASP Top 10:2021 是網頁安全領域中經常被拿來參考的弱點種類，請問下列關於 OWASP Top 10:2021 的描述何項錯誤？ (A) A01:2021 - Broken Access Control：這個種類通常發生在程式沒有做好權限控管，導致可以讀取到其他使用者的資料，甚至可以切換權限 (B) A03:2021 - Injection：這個種類的弱點風險等級通常偏高，因為無論是 SQL Injection、Command Injection、Code Injection 都有可能造成伺服器資料外洩或是被取得控制權，必須嚴加防範 (C) A06:2021 - Vulnerable and Outdated Components：這個種類指的是企業的開發人員或系統維運人員沒有定期檢查程式套件、開發框架、作業系統的版本，導致企業使用的版本存在已知的弱點 (D) A10:2021 - Server-Side Request Forgery (SSRF)：這個種類的弱點經常被用在網路探勘或存取內網資料，不過因為這個種類排在 OWASP Top 10 第十名，威脅性不高，也很難搭配其他弱點一起使用，通常企業不需要優先修補

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 7 頁，共 15 頁

B	20. 面對來自於供應鏈的資安威脅防護，下列敘述何者正確？ (A) 供應商系統可以開放在網路上，不需要限制來源 (B) 供應商所提供的軟硬體，要經過測試檢驗方可上線 (C) 外部採購的軟體可以直接安裝使用 (D) 軟體供應鏈固定即可不需要評估漏洞風險
B	21. 下列哪一項是幽靈攻擊 (Spectre) 利用現代處理器的特性來竊取敏感資訊？ (A) 記憶體交換 (Memory Swapping) (B) 分支預測 (Branch Prediction) 和推測執行 (Speculative Execution) (C) 虛擬記憶體 (Virtual Memory) (D) 多重執行緒處理 (Multithreading)
D	22. 下列何項較「不」屬於作業系統上常見的惡意程式？ (A) 電腦病毒與蠕蟲 (Viruses & Worms) (B) 特洛伊木馬程式 (Trojan) (C) 間諜軟體與廣告軟體 (Spyware & Adware) (D) 網路釣魚郵件 (Phishing) 的連結
D	23. XSS (Cross-Site-Scripting) 與 SQLi (SQL Injection) 兩種攻擊方式均與輸入程式碼有關。請問關於這兩種攻擊的差別，下列敘述何項最為適當？ (A) SQLi 是一種用於攻擊 SQL 資料庫的駭客手法，而 XSS 攻擊可以存在於許多不同類型的程式語言，如 Python (B) XSS 攻擊用於從資料庫竊取資料，而 SQLi 攻擊用於將使用者重定向到攻擊者可以從中竊取資料的網站 (C) XSS 是一種用於攻擊 SQL 資料庫的駭客手法，而 SQLi 攻擊可以存在於許多不同類型的應用程式中 (D) SQLi 攻擊用於從資料庫竊取資料，而 XSS 攻擊用於將使用者重定向到攻擊者可以從中竊取資料的網站

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 8 頁，共 15 頁

D	24. 下列何項觀點才是正確的程式安全開發的精神？ (A) 可以交由工具來把關，針對掃出來的問題進行修復即可 (B) 資料都有加密儲存，而且透過安全通道傳輸，所以不會有問題 (C) 時間目標才是王道，安全是額外附加，所以最後再考慮 (D) 遵循安全開發指引，於寫程式初期即考量安全設計的概念
C	25. 在安全開發的最佳實踐中，為了防止使用者輸入惡意內容導致安全漏洞，開發者應該採取下列哪一種措施？ (A) 將使用者的輸入直接以常數的方式撰寫在原始碼 (Hard-Coding) (B) 將使用者輸入的資料直接儲存在資料庫中 (C) 驗證 (Validation) 並淨化 (Sanitization) 所有使用者輸入 (D) 僅針對管理員帳號檢查輸入
C	26. Cigital 機構所提出之軟體安全開發生命週期架構 (Software Security Develop Life Cycle, SSDLC) 中，下列何項「不」在該生命週期階段中？ (A) 需求定義 (Requirement Definition) (B) 設計 (Design) (C) 報告 (Report) (D) 部署 (Deployment)
B	27. 下列何項「不」屬於程式開發過程中的安全檢測項目？ (A) 動態應用系統安全測試 DAST (Dynamic Application Security Testing) (B) 系統冒煙測試 (Smoke Testing) (C) 原始碼測試 (Source Code Testing) (D) 白箱測試 (White Box Testing)

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 9 頁，共 15 頁

C	28. 在開發安全的應用程式時，使用者密碼應該如何安全儲存最為適當？ (A) 儲存於設定檔，方便管理員查詢 (B) 使用 SHA-1 進行雜湊後存儲 (C) 使用鹽（Salt）與 SHA-2 雜湊演算法存儲 (D) 直接儲存不做處理
D	29. 為了躲避安全研究人員的分析與惡意軟體偵測機制，某些惡意程式會嘗試偵測自己是否執行於沙盒環境（Sandbox）內，並在偵測到時隱藏或延遲執行惡意行為。下列何種方法「不」是惡意程式常見的沙盒偵測技術？ (A) 檢查系統運行時間是否極短，以判斷是否為剛啟動的虛擬環境 (B) 嘗試存取特定的虛擬機或沙箱環境特徵，如硬體資訊 (C) 檢查是否有鍵盤或滑鼠輸入活動，以確認系統是否由真人操作 (D) 自動將自身程式碼重新加密以防止靜態分析
B	30. 下列何項「不」是常用的弱點分類或評分標準？ (A) CWE（Common Weakness Enumeration） (B) CSRS（Common Security Risk System） (C) CVE（Common Vulnerability and Exposure） (D) CVSS（Common Vulnerability Scoring System）
D	31. 下列何項「不」是常用來觀察駭客攻擊行為的模型（Models）？ (A) MITRE ATT&CK (B) MITRE D3FEND (C) MITRE ENGAGE (D) MITRE DEFEND

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 10 頁，共 15 頁

C	32. 為了有效防禦惡意程式的入侵，下列哪一種做法最能幫助快速發現並處理可能存在的弱點？ (A) 一年一度書面審查所有系統和軟體 (B) 依賴員工在發現問題時主動報告 (C) 定期執行弱點掃描並立即修復發現的漏洞 (D) 將所有檔案加密以防止惡意程式進行存取
A	33. 若一台設備已無法修補特定漏洞，下列哪一項防護措施最「不」能有效防止攻擊者利用該漏洞進行攻擊？ (A) 安裝最新的應用程式更新，降低可能被利用的攻擊面 (B) 使用虛擬補丁技術，在網路層面阻止針對漏洞的攻擊流量 (C) 對該設備進行嚴格的存取控制，限制只有特定來源能夠存取 (D) 啟用入侵偵測和防禦系統（IDS/IPS），監控並阻擋可疑流量
C	34. 關於密碼（Password）要求的描述，下列何項最「不」適切？ (A) 於不同之應用系統中，系統管理者不使用相同密碼（Password） (B) 即使是系統管理者帳號，密碼（Password）不與任何人共享使用 (C) 為了套裝軟體維護上的安全要求，由廠商預先提供之密碼（Password），不要隨意變更 (D) 當使用密碼（Password）作為系統登入鑑別資訊時，需套用高強度密碼

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 11 頁，共 15 頁

B	35. 資料安全在量子時代遭受極大挑戰，下列因應對策何者較為適切？ (A) CPC 中央處理加密 (B) PQC 後量子加密 (C) EEG 橢圓曲線圖 (D) AGV 自動圖形向量
C	36. 某公司每次完整備份的資料量約略少於 800GB，公司的顧問建議在備份媒介的選擇上，每一個單一的儲存媒介，需可以完整存放其一次的備份資料，請問下列哪種儲存媒介較為合適？ (A) BD-R (B) LTO-2 (C) LTO-4 (D) DAT320
C	37. 對於保護儲存設備中的資料不被第三方竊取或篡改，下列何者描述最為適切？ (A) 使用對稱加密演算法，並將加密金鑰儲存在同一個設備上 (B) 可以對資料進行 Base64 編碼以隱藏資料內容 (C) 對資料進行加密保護，並額外使用 HMAC 來驗證資料完整性 (D) 將資料壓縮後再儲存於儲存設備
C	38. 當企業需要永久刪除機密資料，使用下列何種方法處置最為安全？ (A) 在作業系統中刪除檔案並清空資源回收筒 (B) 對硬碟使用標準格式化 (C) 使用資料覆寫工具或物理銷毀 (D) 將硬碟存放於安全的地方以防止存取

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：II2 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 12 頁，共 15 頁

C	39. 依據「資通安全責任等級分級辦法」之資通系統防護基準規範，以下對於「事件日誌與可歸責性」的描述何者正確？ (A) 資通系統應使用格林威治標準時間（GMT）作為系統的時戳標準 (B) 只要有需要，都可以任意存取日誌紀錄 (C) 從日誌完整性防護必須分為事前預防、事中監視及事後驗證等三種面向，可驗證日誌內容是否曾經遭到異動 (D) 將日誌備份至原日誌系統不同之實體系統，以驗證資料機密性
D	40. 日誌管理要求應定期執行日誌備分的任務，關於日誌管理的敘述下列何項有誤？ (A) 定期備份日誌至與原系統外之其他實體系統，以避免因實體主機損毀而造成原始資料與備份資料一併丟失 (B) 常見的日誌備份方式有建置日誌伺服器、NAS 及雲端空間等 (C) 可以利用磁碟與磁帶等儲存媒體存放備份資料 (D) 為避免備份相關弊端產生，驗證人員於檢視機關日誌紀錄時，不可以訪談相關權責人員

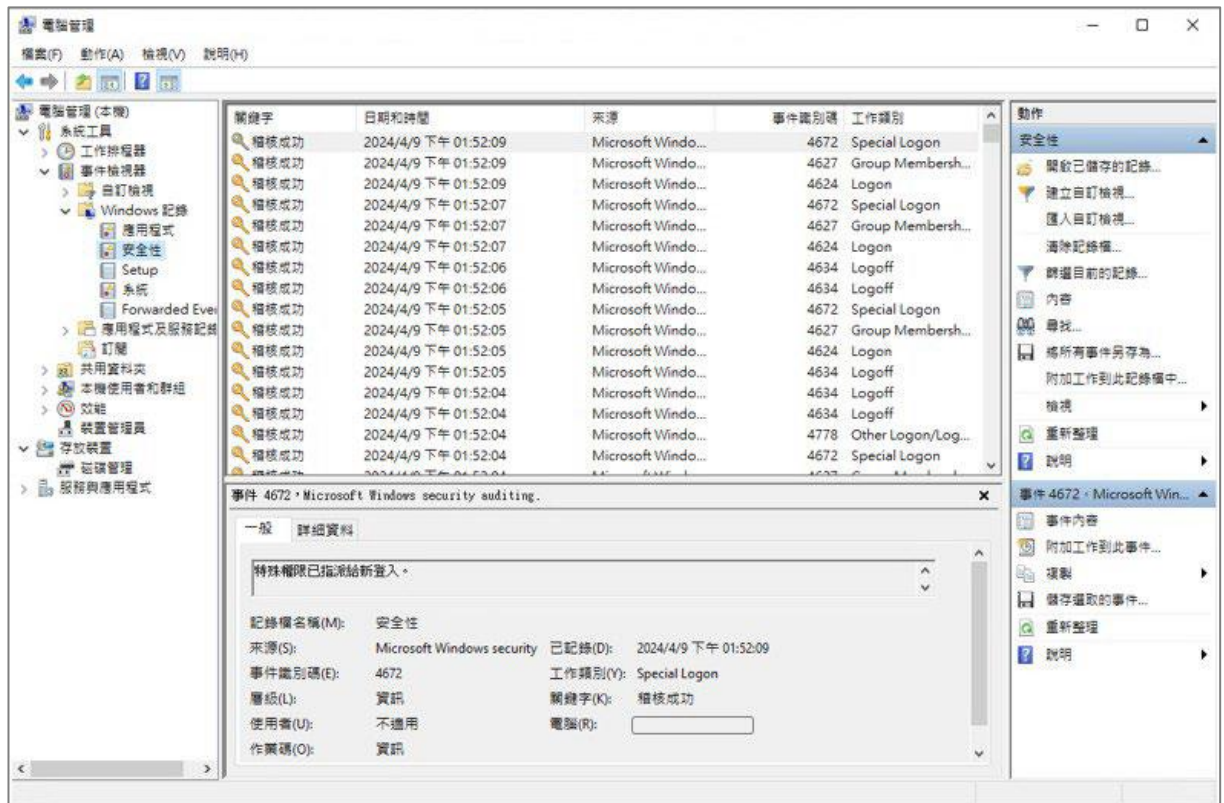
114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 13 頁，共 15 頁

- B 41. 請問如果你想要新建立一個常用的篩選結果，可以快速的進行查看，請問在附圖的介面中，該如何開始你的第一步？



- (A) 從右側動作中的「開啟已儲存的記錄」開始
- (B) 從右側動作中的「建立自訂檢視」開始
- (C) 從右側動作中的「儲存選取的事件…」開始
- (D) 從右側動作中的「將所有事件另存為…」開始

- D 42. 某網路管理員收到要求，需要開放在 DMZ 區的伺服器 A，讓其可以透過 RFC 5424 的協定寫入相關的日誌記錄到 DMZ 區以外的區域中的伺服器 B，請問以下列何項設定較為合適？

- (A) 允許所有伺服器到伺服器 B 的連線
- (B) 允許所有來自伺服器 A 到伺服器 B 的連線
- (C) 允許伺服器 A 至伺服器 B 中 TDP Port 514 的連線
- (D) 允許伺服器 A 至伺服器 B 中 UDP Port 514 的連線

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 14 頁，共 15 頁

B	43. 在數位鑑識調查中，為確保證據的完整性並能在法庭上被接受，下列哪一項原則較「不」適切？ (A) 在證據的扣押、蒐集、保管和運送過程中，應確保資料的一致性與完整性 (B) 為保持證據完整性，應利用加密機制保護數位證據 (C) 確保所有證據的取得、分析和儲存過程都被完整記錄並可被重現 (D) 其他人依據蒐證人員宣稱的鑑識程序應能得出相同的鑑識結果
B	44. 企業使用雲端服務時，下列哪一個資安技術較「不」屬於企業維運人員優先需要關注的？ (A) 身分識別與存取管理 (B) 實體安全 (C) 網站應用程式防火牆（WAF） (D) 資料隱私保護
B	45. 使用雲端資料庫與應用程式十分方便，但若設定稍有不慎將導致資料外洩或是服務遭到攻擊，下列何項是因設定不慎而導致問題，同時也列為 OWASP TOP 10 2021 之一的漏洞？ (A) Cryptographic Failures (B) Security Misconfiguration (C) Vulnerable and Outdated Components (D) Software and Data Integrity Failures
B	46. 智慧手機 APP 開發過程中，為了避免惡意程式的竊取或入侵，應該採用以下列何項方法？ (A) 使用明文儲存使用者的所有資料 (B) 定期更新和維護第三方程式庫 (C) 允許 APP 自動接受所有未經驗證的 SSL 憑證 (D) 為確保最佳的使用者體驗，故開放 APP 所有權限

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I12 資訊安全技術概論

考試日期：114 年 5 月 17 日

第 15 頁，共 15 頁

C	47. 在台灣，行動裝置的 App 要送「行動應用 App 基本資安檢測實驗室」檢測時，如果有金流及會員資料的，是屬於下列何項等級？ (A) L1 (B) L2 (C) L3 (D) L4
A	48. 在行動裝置安全機制中，下列何種技術可有效防止惡意應用程式竊取其他程式中的使用者資料？ (A) APP 沙盒（Application Sandbox） (B) DNS 解析（DNS Resolution） (C) 網路位址轉譯（Network Address Translation） (D) 藍牙配對（Bluetooth Pairing）
B	49. 在物聯網安全中，下列何種技術可有效防止設備與伺服器之間的通訊被竊聽或篡改 (A) Telnet (B) HTTPS (C) FTP (D) SNMPv1
D	50. 下列何項「不」是物聯網設備常見的問題？ (A) 預設密碼或使用弱密碼 (B) 缺乏安全的更新機制 (C) 缺乏設備管理 (D) 加密機制失效